

ISO 27001 – Informe de Gestión de Incidentes

Vulnerabilidad de SQL Injection (DVWA)

Introducción

Este informe documenta la identificación y explotación controlada de una vulnerabilidad de tipo SQL Injection en la aplicación Damn Vulnerable Web Application (DVWA). La prueba se realizó en un entorno de laboratorio controlado, utilizando una máquina virtual con Debian, con fines educativos y de aprendizaje en seguridad informática.

Descripción del Incidente

Durante la evaluación de seguridad de DVWA, se detectó una vulnerabilidad de SQL Injection en el módulo denominado "SQL Injection". Esta falla permite que un atacante manipule las consultas SQL enviadas a la base de datos a través de campos de entrada que no están correctamente validados.

Método de SQL Injection Utilizado

Para demostrar la vulnerabilidad, se utilizó el siguiente payload sencillo en el campo de entrada de usuario:

1' OR '1'='1

Este comando funciona porque la condición '1'='1' siempre es verdadera. Al inyectarse en la consulta original, provoca que el sistema devuelva información sin aplicar las validaciones o restricciones esperadas, permitiendo el acceso no autorizado.

Impacto del Incidente

- Acceso no autorizado a información almacenada en la base de datos.
- Posible exposición de datos sensibles, como credenciales de usuarios.
- Riesgo para la confidencialidad, integridad y disponibilidad de la información.

Recomendaciones

- 1 Validación de Entradas: Implementar validaciones estrictas y el uso de consultas preparadas (prepared statements) para evitar inyecciones SQL.
- 2 Pruebas de Seguridad: Realizar auditorías y pruebas de penetración de forma periódica para detectar vulnerabilidades a tiempo.
- 3 Capacitación: Formar a desarrolladores y personal técnico en buenas prácticas de desarrollo seguro.

Conclusiones

Este ejercicio demuestra cómo una vulnerabilidad básica de SQL Injection puede comprometer seriamente la seguridad de una aplicación web. Incluso ataques simples pueden tener un alto impacto si no se aplican controles de seguridad adecuados. La implementación de buenas prácticas y controles alineados con la norma ISO 27001 es fundamental para proteger los sistemas de información.